

Содержание



Присоединяйтесь к нашему сообществу, чтобы начать свой путь в сфере кибербезопасности уже сегодня!

Узнать больше

Шпаргалка по Burp Suite — полное руководство по командам 2026



вы попали на страницу целевого веб-приложения. Прежде чем запускать эксплойт или тестировать какой-либо параметр, вам нужно увидеть, что на самом деле происходит между браузером и сервером: каждый запрос, каждый ответ, каждое скрытое поле и файл cookie. Именно это и делает Burp Suite, и делает это лучше, чем любое другое доступное решение.

Burp Suite — это платформа для тестирования безопасности веб-приложений на основе Java, разработанная компанией PortSwigger. По своей сути это перехватывающий HTTP/S-прокси, который находится между вашим браузером и целевым сервером, обеспечивая полный обзор и контроль над каждым пакетом веб-трафика. Но называть его «просто прокси» — все равно что называть швейцарский армейский нож «просто лезвием».

Помимо перехвата, Burp Suite включает в себя полный набор инструментов для ручного тестирования, автоматического сканирования, фаззинга, анализа сессий, кодирования/декодирования, а также возможность расширения с помощью сотен плагинов, созданных сообществом. Это стандартный отраслевой инструмент для тестирования веб-приложений на проникновение, знание которого является обязательным для получения сертификатов OSCP, CEH, BSCP, eWPT и практически всех существующих сертификатов по веб-безопасности.

Три издания

Издание	Что вы получаете	Лучше всего подходит для
Сообщество (Бесплатно)	Прокси, ретранслятор, интродер (с ограничением скорости), декодер, компаратор, секвенсор, расширения	Студенты, лаборатории OSCP, CTF, обучение

Взламывающие
Петли



Scanner,
ость Intruder,
исширенные

Профессиональные
пентестеры,
масштабная
программа Bug
Bounty

	фильтры	
Предприятие	Облачное размещение, интеграция CI/CD, командные функции, сканирование по расписанию	Команды по обеспечению безопасности, конвейеры DevSecOps

Что охватывает это руководство

Во всем руководстве используется версия Burp Suite Community Edition, если не указано иное. Функции, доступные только в версии Professional, отмечены пометкой Pro.

2. Установка и первоначальная настройка

Системные требования

Требование	Подробные сведения
Java	Java 17 или более поздняя версия (входит в состав установщика — отдельная установка не требуется)
ОЗУ	Минимально 4 ГБ, для комфортной работы рекомендуется 8 ГБ

Взламывающие Петли



.linux (любая современная версия)

ity предустановлен. Обновите его с
помощью: `sudo apt update && sudo apt install burpsuite`

Загрузка Burp Suite

Перейдите непосредственно на официальный сайт — не скачивайте программу со сторонних ресурсов:

- <https://portswigger.net/burp/communitydownload>

Запустите установщик для вашей ОС. Входящая в комплект JRE автоматически обрабатывает Java — ручная настройка не требуется.

Первый запуск

- Откройте Burp Suite. В версии Community Edition выберите «Временный проект» → «Далее» → «Использовать настройки Burp по умолчанию» → «Запустить Burp».
- В версии Professional вы можете создавать и сохранять именованные проекты, что позволяет сохранять вашу работу между сеансами.
- Главное окно загружается с активной вкладкой **Панель управления**. Вы увидите панели «Журнал событий» и «Активность по задачам» — пока не обращайтесь на них внимания.

3. Настройка прокси — правильный способ

Прокси — это основа всего в Burp Suite. Если вы пропустите этот этап настройки или сделаете что-то неправильно, вы не увидите трафик, столкнетесь с ошибками SSL или не сможете ничего перехватить. Есть два способа — выберите тот, который подходит для вашего рабочего процесса.

Способ 1: встроенный браузер Burp (рекомендуется для начинающих)

- Запустится браузер на основе Chromium, предварительно настроенный на маршрутизацию всего трафика через Burp Suite на порту 8080.
- Перейдите на любой целевой сайт. Вы сразу увидите запросы в истории HTTP.
- Установка сертификата ЦС не требуется — Burp автоматически обрабатывает HTTPS во встроенном браузере.

Способ 2: Firefox + FoxyProxy (рекомендуется для опытных пользователей)

Это позволяет использовать обычный браузер и быстро включать и выключать прокси:

Шаг 1 — Настройте прослушиватель Burp:

- Перейдите в Прокси → Настройки прокси → убедитесь, что прослушиватель включен 127.0.0.1:8080.

Шаг 2. Установите FoxyProxy в Firefox:

- Установите FoxyProxy Standard из магазина дополнений Firefox.
- Добавьте новый прокси: тип = HTTP, хост = 127.0.0.1, порт = 8080.
- Включайте его всякий раз, когда хотите направить трафик через Burp.

Шаг 3. Установите сертификат центра сертификации PortSwigger (критически важен для HTTPS):

- При активном FoxyProxy и запущенном Burp перейдите по адресу `http://burpsuite` в Firefox.
- Нажмите Сертификат центра сертификации, чтобы загрузить `cacert.der`.
- В Firefox: Настройки → Конфиденциальность и безопасность → Просмотр сертификатов → Центры сертификации → Импорт. Отметьте «Доверять этому центру сертификации для идентификации веб-сайтов».
- Перезапустите Firefox. Теперь HTTPS-трафик будет корректно перехватываться без ошибок SSL.



Проверка настроек

Быстрая проверка работоспособности — при запущенном Burp и активном прокси:

- Нажмите **Прокси** → **История HTTP**.
- Перейдите на любой сайт по протоколу HTTP или HTTPS.
- Вы сразу увидите запросы в таблице истории.
- Если перехват включен (**Кнопка «Перехват включен» выделена**), Burp будет приостанавливать каждый запрос. Нажмите **«Далее»**, чтобы продолжить, или **«Отмена»**, чтобы прервать.
- Для пассивного просмотра и разведки отключите функцию перехвата и позвольте трафику свободно поступать в HTTP History.

Pro tip: right-click on everything

Burp's real power lives in context menus. Right-click any request in any tab and you'll see options to Send to Repeater, Send to Intruder, Send to Decoder, copy as curl command, and more. Developing the right-click habit is the fastest way to level up your Burp workflow.

4. Tab-by-Tab Reference: Every Tool Explained

Burp Suite is organized into tabs, each representing a distinct tool. Here's every tab you need to know, what it does, and when to use it.

Proxy

The central hub of Burp Suite. Every request and response passing through Burp appears here. You'll spend the majority of your testing time with Proxy open.

Взламывающие Петли



Intercept	Pauses requests/responses so you can view and modify them before forwarding. Toggle with the button or Ctrl+T.
HTTP History	Log of all HTTP/S traffic through the proxy. Sortable by host, method, URL, status, length, MIME type. Your primary browsing record.
WebSockets History	Same as HTTP History but for WebSocket messages. Essential for testing modern SPAs and real-time apps.
Proxy settings	Configure listener ports, match/replace rules, TLS settings, and upstream proxy chaining.

Key actions in HTTP History

- Click any column header to sort. Click again for reverse. Click a third time to return to insertion order.
- Click the filter bar at the top to filter by host, status code, MIME type, search term, or scope.
- Right-click any request → `Add to scope` to define your target scope. In-scope requests are highlighted.
- The `Inspector` panel on the right parses headers, cookies, query parameters, and body parameters into editable sections. Saves time versus manual editing.

Match and Replace (underused but powerful)

Found in Proxy settings. Lets you automatically modify requests or responses on the fly without manual interception:

- Replace `User-Agent` headers across all requests.

Target

The Target tab gives you a structured view of everything Burp has seen about your target — organised as a site map and a scope definition.

Sub-tabs

Sub-tab	What it does
Site map	Tree view of all hosts, directories, and endpoints discovered. Colour-coded by response type. Drill down into any endpoint to see full request/response.
Scope settings	Define what's in scope using URL prefixes, regex patterns, or host/protocol filters. Everything out-of-scope is filtered from history and tools.
Issue activity	Pro only. Lists vulnerabilities found by the active scanner.

Setting your scope (do this first on every engagement)

- In Site map, right-click the target host → Add to scope.
- A dialog will ask if you want to stop logging out-of-scope requests — click Yes to keep your history clean.
- Use the Scope settings tab for precise control — you can include/exclude specific paths with regex patterns.
- With scope defined, Intruder, Scanner, and Spider tools automatically respect it.



Scanner Pro only

The active vulnerability scanner. It automatically crawls your target and tests for OWASP Top 10 vulnerabilities including SQL injection, XSS, SSRF, path traversal, [XXE](#), and dozens more. Generates a report you can export for client deliverables.

- To scan: right-click any request → Scan. Or use the Dashboard → New Scan.
- Configure scan type: Crawl only, Audit only, or Crawl and Audit.
- Results appear in Target → Issue activity with severity ratings (High/Medium/Low/Info).
- Community alternative: use ZAP's passive scanner alongside Burp, or manually test with Repeater + Intruder.

Community alternative for scanning

Burp Community has no active scanner. For automated scanning on a budget, pair Burp Community with OWASP ZAP (free) or Nikto for server-level scanning. See the Nikto Cheat Sheet on hackingloops.com for a full guide.

Intruder

The fuzzing and brute-force engine. Send any request to Intruder, mark the positions you want to fuzz, load a payload list, and Intruder fires off hundreds or thousands of variations automatically. Covered in full detail in Section 5.



ately 1 request/second, making high-volume
speed, use Hydra, ffuf, or Turbo Intruder (a free

Burp extension) instead. Intruder in Community is still useful for small fuzzing tasks and logic testing.

Repeater

The manual testing workhorse. Send any request to Repeater, modify it however you like, and resend it — as many times as you want. Every parameter change, header modification, or payload test happens here. Covered in full in Section 6.

Sequencer

Analyses the randomness of tokens — session cookies, CSRF tokens, password reset tokens. If tokens are predictable, they can be forged. Sequencer captures a batch of tokens and runs statistical tests to determine their entropy.

- How to use: intercept a response containing a token → right-click → Send to Sequencer.
- In Sequencer, click `Start live capture` to collect token samples automatically.
- After 100+ samples, Burp runs an analysis and tells you the effective entropy in bits. Below 64 bits is concerning; below 32 bits is a critical finding.
- Common use cases: session cookie analysis, CSRF token randomness testing, password reset token prediction.

Decoder

A built-in encoding/decoding and hashing tool. Paste any string and convert it between formats with one click — or chain multiple transformations.

Encoding type

What it handles

Взламывающие Петли



t-encoded strings. Essential for parameter

HTML encoding	Encode/decode HTML entities (&, <, ', etc.)
Base64	Standard and URL-safe Base64. Common in JWTs, session tokens, file uploads.
Hex	Hexadecimal encoding. Useful for binary data and raw bytes.
Gzip / Zlib	Compress and decompress. Useful for compressed POST bodies.
Hash	MD5, SHA-1, SHA-256, SHA-512. Hash any input for comparison.

Chaining transformations

Decoder supports chaining — decode Base64, then URL-decode the result, then hash it. This is invaluable when dealing with obfuscated payloads or complex token structures.

Comparer

Differs two requests or responses to spot differences. Send two items from any other tool and Comparer highlights what changed — at the word level or byte level.

- Use case: compare a 200 OK versus a 403 Forbidden response to understand what access control mechanism is in play.
- Use case: compare responses before and after authentication to identify session-bound content.
- Use case: compare two similar user accounts' responses to detect Insecure Direct Object Reference (IDOR) vulnerabilities.

Logger Pro Only

A comprehensive traffic log with advanced filtering. More powerful than Proxy's HTTP History for long engagements — logs all tool-generated traffic (not just proxy traffic), supports custom filters, and can log to file.

Organizer

Save and annotate interesting requests during an engagement. Add notes, mark requests as reviewed, and keep your findings organised for the report-writing phase.

- Right-click any request in any tool → Send to Organizer.
- Add a note describing why you saved it — makes report writing dramatically faster.
- Export saved requests for documentation.

5. Burp Suite Intruder: All 4 Attack Modes with Examples

Intruder is Burp Suite's automated request-modification engine. You define injection points in a request — called positions — and Intruder iterates through a payload list, inserting each payload into those positions and sending the request. The results table shows every response so you can spot anomalies.

Setting Up an Intruder Attack

1. Send a request to Intruder: right-click any request in Proxy History → Send to Intruder.
2. Go to the **Positions** tab. Burp auto-highlights positions with § markers. Clear these and manually select what you want to fuzz using the Add § button.
3. Go to the **Payloads** tab. Load a wordlist (Simple list, Runtime file, Clipboard, etc.).
4. Select your Attack type (see below). Click **Start attack**.

Взламывающие Петли



is, Length, or any column to find anomalous

Attack Mode 1: Sniper

The simplest and most common mode. Uses a single payload list. Tests each position one at a time, leaving all other positions unchanged.

Property	Details
Payload sets	1
How it works	Iterates each payload through each position sequentially. With 3 positions and 100 payloads → 300 requests total.
Best for	Fuzzing a single parameter, wordlist attacks on one input field, basic injection testing.

Example scenario: Testing a search field for XSS. You have one position marked around the search term. Load an XSS payload list. Sniper fires each XSS payload into the search field and you review which responses reflect the payload.

Attack Mode 2: Battering Ram

Like Sniper but inserts the same payload into all positions simultaneously on each request.

Property	Details
Payload sets	1

Взламывающие Петли



y marked position at once. With 3 positions and
:s total.

Best for	When the same value needs to appear in multiple places (e.g., username appears in both cookie and POST body).
----------	---

Example scenario: An application reflects the username in both a cookie and a query parameter. You need both to match for the session to work. Battering Ram keeps them synchronised across all payloads.

Attack Mode 3: Pitchfork

Multiple payload sets — one per position. Iterates through all payload lists simultaneously, like a zip function.

Property	Details
Payload sets	One per position
How it works	Position 1 gets payload 1 from list A. Position 2 gets payload 1 from list B. Then payload 2 from A with payload 2 from B. Stops at the end of the shortest list.
Best for	Credential stuffing — testing known username:password pairs from a breach dump.
Request count	Equal to the length of the shortest payload list.

Example scenario: You have a list of 50 leaked username:password pairs. Mark the username field as Position 1 and password as Position 2. Load usernames as Payload

Multiple payload sets — tests every possible combination. The nuclear option.

Property	Details
Payload sets	One per position
How it works	Tests every combination of payloads across all positions. With 100 usernames and 100 passwords → 10,000 requests.
Best for	Brute-force attacks when you have separate username and password wordlists with no known pairing.
Warning	Request count grows multiplicatively. Plan carefully to avoid detection or getting blocked.

Example scenario: You have a list of 20 likely usernames and a list of 200 common passwords. You don't know which pairs are valid. Cluster Bomb tests all 4,000 combinations and flags any that return a different response (e.g., 302 redirect instead of 401).

⚠ **Community throttle — use these alternatives for speed**

Burp Community limits Intruder to roughly 1 request/second. For high-volume attacks in a time-sensitive engagement:

- Turbo Intruder (free Burp extension) — bypasses the throttle completely, Python-scriptable, handles async requests.
- ffuf — faster for directory/parameter fuzzing. See the Gobuster & ffuf Cheat Sheet on hackingloops.com.



6. Выпрямите Repeater. Manual Testing Masterclass

Repeater is where you do the real work. While Intruder automates broad testing, Repeater is for precision — sending the same request over and over with carefully crafted modifications and analysing each response in detail. If Intruder is the shotgun, Repeater is the scalpel.

Core Repeater Workflow

6. Send a request to Repeater: right-click in Proxy History → Send to Repeater.
7. Always send an unmodified baseline request first. Note the response: status code, body length, any tokens or IDs.
8. Modify one parameter at a time. Change a value, add a character, insert a payload. Send the request.
9. Compare the response to your baseline. Look for: different status codes, different response lengths, error messages, reflected input, time delays, or behavioural changes.
10. Iterate. Each finding in Repeater becomes evidence in your report.

Repeater Tips

- Double-click any tab to rename it — essential when you have 20 tabs open during a complex engagement.
- Click the + next to the tabs to create Tab Groups — group related requests together (e.g., all auth tests, all IDOR tests).
- Copy a URL and right-click inside a Repeater request window → Paste URL as request — instantly creates a raw GET request for any URL without going through the proxy.
- Use the **Inspector** panel on the right to edit headers, cookies, and query parameters as structured fields rather than raw text.

Взламывающие Петли



tions: Raw, Pretty (formatted), Render (live
to see exactly how a reflected payload

- Use **Search** in the response pane (Ctrl+F) to quickly find your injected payload in large responses.

Common Repeater Test Cases

Vulnerability type	What to modify in Repeater
SQLi testing	Append ' or 1=1– to a parameter. Watch for database errors, different data returned, or timing differences.
XSS testing	Insert <script>alert(1)</script> or other payloads. Use Render view to see if they execute.
IDOR testing	Change object IDs (user_id=1234 → user_id=1235). Check if you can access another user's data.
Auth bypass	Remove or modify auth headers/cookies. Try setting role=admin in cookies or JWT claims.
SSRF testing	Replace URL parameters with internal IPs (http://127.0.0.1, http://169.254.169.254/latest/meta-data/).
Path traversal	Modify file path parameters with ../../etc/passwd or ..\\..\\windows\\system32\\drivers\\etc\\hosts.



7. Burp Suite Decoder & Comparer

Decoder: Practical Cheat Sheet

You can access Decoder from any tool by selecting text → right-click → Send to Decoder. Or navigate to the Decoder tab directly.

Task	Example input	Result
URL decode	admin%27+OR+%271%27%3D%271	admin' OR '1'='1
Base64 decode	YWRtaW46cGFzc3dvcmQ=	admin:password
HTML decode	<script>alert(1)</script>	<script>alert(1)</script>
Hex decode	61646d696e	admin
Chain: URL then Base64	YWRtaW4lM0FwYXNzd29yZA==	URL decode → admin%3Apassword → Base64 decode → admin:password

Comparer: When to Use It

- IDOR detection: compare two responses from different user IDs. If they're identical, access control may be broken.

Взламывающие
Петли



ngths between a true condition (1=1) and
d SQLi.
ated vs. unauthenticated response to

understand what's protected.

- CSP analysis: compare security headers across different pages to find inconsistencies.

8. Keyboard Shortcuts Cheat Sheet (Complete Table)

This is the section to bookmark. Every shortcut below is confirmed for Burp Suite on Windows/Linux. macOS users: replace Ctrl with Cmd.

Global Shortcuts

Action	Shortcut
Send request to Repeater	Ctrl + R
Send request to Intruder	Ctrl + I
Forward intercepted request	Ctrl + F
Toggle Proxy intercept on/off	Ctrl + T
Drop intercepted request	Ctrl + D
Open new Repeater tab	Ctrl + Shift + R

Взламывающие Петли



Ctrl + Shift + C

Tab Navigation

Action	Shortcut
Go to Dashboard	Ctrl + Shift + D
Go to Target	Ctrl + Shift + T
Go to Proxy	Ctrl + Shift + P
Go to Intruder	Ctrl + Shift + I
Go to Repeater	Ctrl + Shift + R
Go to Decoder	Ctrl + Shift + E
Move to next tab	Ctrl + Tab
Move to previous tab	Ctrl + Shift + Tab

Request/Response Editor Shortcuts

Action	Shortcut

Взламывающие Петли



	<code>Ctrl + U</code>
	<code>Ctrl + Shift + U</code>
HTML-encode selected text	<code>Ctrl + H</code>
HTML-decode selected text	<code>Ctrl + Shift + H</code>
Base64-encode selected text	<code>Ctrl + B</code>
Base64-decode selected text	<code>Ctrl + Shift + B</code>
Select all in editor	<code>Ctrl + A</code>
Search in editor / response	<code>Ctrl + F</code>
Copy selected text	<code>Ctrl + C</code>
Paste	<code>Ctrl + V</code>
Undo	<code>Ctrl + Z</code>
Redo	<code>Ctrl + Y</code>
Delete current line	<code>Ctrl + Delete</code>

Send request (from Repeater)	Ctrl + Enter
View previous request/response	Ctrl + <
View next request/response	Ctrl + >

9. Essential Extensions: The Best BApps for Pentesters

Extensions are installed from the Extensions tab → BApp Store. They’re what transform Burp Suite from a great tool into an extraordinary one. Here are the most impactful free extensions every pentester should have installed.

Recon & Enumeration

Extension	What it does	Best for
Param Miner	Automatically discovers hidden GET/POST parameters, headers, and cookies that aren't visible in the normal request. Uses smart guessing and response analysis.	Finding hidden parameters in bug bounty scope
JS Link Finder	Parses all JavaScript files in the proxy traffic and extracts URLs, API endpoints, and paths — even from minified or obfuscated code.	API endpoint discovery, mapping attack surface

Взламывающие Петли

	 ap and extracts me. Builds a get traffic.	Building custom parameter wordlists
Retire.js	Identifies outdated JavaScript libraries with known CVEs in HTTP responses. Flags vulnerable versions automatically.	Quick wins on legacy apps

Injection & Exploitation Testing

Extension	What it does	Best for
Hackvertor	Handles complex multi-layer encoding and decoding chains. Build transformation pipelines to handle obfuscated payloads automatically in Intruder/Repeater.	Heavily encoded apps, obfuscated parameters
SQLiPy	Integrates SQLmap directly inside Burp Suite. Right-click any request → SQLiPy Scan. Launches SQLmap against the selected request without leaving Burp.	Automated SQLi testing within Burp workflow
CSRF Scanner	Passively scans all proxy traffic for forms and requests missing CSRF protection. Flags potential CSRF vulnerabilities automatically.	CSRF finding during passive browsing
Upload Scanner	Tests file upload endpoints for dangerous file type acceptance, extension bypasses, and polyglot files.	File upload vulnerability testing



JWT Editor	Decodes JWTs in Proxy traffic, lets you modify claims, re-sign with a different key, test for algorithm confusion (RS256→HS256), and test with weak/null keys.	JWT attacks, BSCP, HackTheBox JWT challenges
SAML Raider	Intercepts and modifies SAML assertions. Test for XML signature wrapping, XXE in SAML, and forged assertions in SSO flows.	Enterprise app testing, SSO security assessments
AuthMatrix	Maps user roles to URLs and automatically tests whether each role can access each endpoint. Identifies broken access control systematically.	Multi-role apps, privilege escalation testing
Session Auth Tester	Automates testing authenticated endpoints with modified/invalid/no session tokens to identify broken authentication.	Auth flow analysis

Productivity & Reporting

Extension	What it does	Best for

Взламывающие
Петли

	 s Intruder throttle , handles async and high-speed fuzzing. A must-have for Community users.	High-speed fuzzing, race condition testing
Logger++	Advanced traffic logging with custom filter rules, column configuration, and CSV export. Far more powerful than built-in HTTP History for long engagements.	Organised traffic logging, report evidence
Burp Bounty	Profile-based active scanning rules. Write custom scan checks without coding — define patterns and payloads in a GUI.	Custom vulnerability checks for specific targets
Auto Repeater	Automatically re-sends selected requests with defined modifications. Saves time when you need to test the same modification across many requests.	Bulk testing with consistent parameter changes

10. Burp Suite in the Real Pentest Workflow

Knowing each tool in isolation is one thing. Understanding how they connect in a real engagement is another. Here’s how Burp Suite fits into a standard web application penetration test — phase by phase.

Phase 1: Passive Recon & Surface Mapping

Before you touch anything, you need to understand what you’re dealing with.

- Set up Burp proxy. Define your scope in the Target tab.
- Browse the application manually — log in, use all features, explore all page that
Burp’s spider and passive scanner (Pro) or your own browsing build out the Site



» surface hidden parameters as you browse.

» endpoints and paths from JavaScript files.

- Review HTTP History. Identify authentication endpoints, data submission points, file upload handlers, and any API calls.

Phase 2: Vulnerability Discovery

- Use Repeater to test individual parameters manually. Start with low-risk tests (e.g., appending a `'`) and observe responses.
- Use Intruder (Sniper mode) to fuzz input fields with targeted payload lists for XSS, SQLi, path traversal.
- Use Sequencer on session cookies and CSRF tokens to assess token entropy.
- Run `AuthMatrix` to systematically test access control across all user roles.
- Use `CSRF Scanner` passively while browsing to flag unprotected forms.

Phase 3: Exploitation

- Confirmed SQLi? Right-click the request in Burp → `SQLiPy Scan` to launch SQLmap directly. Alternatively, copy the request to a file and run SQLmap with `-r request.txt`. See the [SQLmap Cheat Sheet](#) on hackingloops.com for the full guide.
- Need to enumerate hidden directories? Copy the base URL from Burp's site map and hand it off to Gobuster or ffuf. See the Gobuster & ffuf Cheat Sheet on hackingloops.com.
- Use Repeater for manual exploitation — crafting payloads, chaining vulnerabilities, testing bypass techniques.
- Use `JWT Editor` to test JWT algorithm confusion, null signature, and weak secret attacks.

Phase 4: Evidence Collection & Reporting

- Use Organizer to save all significant requests with notes as you find them.
- Export HTTP History filtered by scope for a complete traffic log.
- Use Logger++ for a cleaner, more filterable export.

as HTML or XML for client deliverables.

Взламывающие
Петли



- In Burp Proxy, right-click the target request → Save item → save as `request.txt`.
- Run: `sqlmap -r request.txt -dbs` to test all parameters in the saved request.
- Or use `SQLiPy` extension for a one-click SQLmap launch directly from Burp. Full SQLmap syntax in the SQLmap Cheat Sheet →

11. Community vs Professional: What Do You Actually Need?

This is the question every Burp user asks sooner or later. Here’s an honest answer.

Feature	Community (Free)	Professional (\$449/yr)
Active vulnerability scanner	✗ Not available	✓ Full DAST scanner
Intruder speed	⚠ Throttled (~1 req/sec)	✓ Full speed, no throttle
Saved projects	✗ Temporary only	✓ Save and reload projects
Burp Collaborator	✗ Not available	✓ OOB interaction testing (SSRF, blind XXE, etc.)
Logger++ tab	✓ Via extension	✓ Built-in Logger
Manual testing (Repeater, Decoder, etc.)	✓ Full access	✓ Full access

Взламывающие Петли



	is free	✓ All extensions
		✓ HTML/XML reports
BSCP certification exam	✓ Community is sufficient	✓ Pro gives an advantage

Honest Recommendation

Community is enough for:

- OSCP, CEH, BSCP exam preparation
- HackTheBox and TryHackMe labs
- CTF competitions
- Learning web application security fundamentals
- Manual testing engagements where you use Repeater heavily

Upgrade to Professional if:

- You are doing paid penetration tests for clients
- You need to run automated scans and deliver scan reports
- You rely on Collaborator for blind SSRF, XXE, or out-of-band injection testing
- You need full Intruder speed for credential attacks at scale
- You want to save and reload project state between sessions

PortSwigger Web Security Academy

PortSwigger offers a completely free learning platform at portswigger.net/web-security with hundreds of hands-on labs covering every OWASP vulnerability class. All labs work perfectly with Burp Suite Community. It's the best free resource for learning Burp Suite by doing.

12. Common Mistakes & Pro Tips

Mistakes That Trip Up Beginners

Взламывающие Петли

Intercepting
≡ Intercept is on, which breaks normal browsing.
Turn OFF and let traffic flow into HTTP History.

Only turn it ON when you want to manually modify a specific request.

Mistake 2: Not defining scope

Without a defined scope, Burp logs traffic from every domain your browser touches — ads, analytics, third-party scripts, CDNs. Your HTTP History becomes a mess. Always define scope first via Target → Scope settings.

Mistake 3: Not installing the CA cert

This is the most common setup mistake. Without the PortSwigger CA certificate trusted by your browser, all HTTPS traffic triggers SSL errors and Burp can't intercept it. Follow the setup steps in Section 3 carefully.

Mistake 4: Using Community Intruder for high-volume brute force

Community Intruder is throttled to ~1 request/second. At that speed, a 10,000-word password list would take nearly 3 hours. Use Turbo Intruder (free extension), Hydra, or ffuf for anything requiring speed.

Mistake 5: Ignoring the Inspector panel

The Inspector (right side of the Proxy and Repeater editors) parses headers, cookies, and parameters into clean, editable rows. Editing values in Inspector is faster and less error-prone than editing raw request text.

Pro Tips from the Field

Tip 1: Right-click everything

Burp's context menus are packed with options most users never discover. Right-click any request: you'll find options to save the item, copy as curl command, highlight in a colour, show response in browser, run an active scan (Pro), and more.

Tip 2: Use colour highlighting to organise findings

Right-click any request in HTTP History → Highlight → choose a colour. Use a consistent system: red = confirmed vulnerability, orange = investigate further, blue = interesting, green = checked and clean. Makes reviewing 500+ requests dramatically faster.

Tip 3: Use Match and Replace for persistent auth headers

Взламывающие Петли

en? Set up a Match and Replace rule to inject
lly. No more copy-pasting tokens into every

Tip 4: Name your repeater tabs

Double-click any Repeater tab to rename it. A tab named 'Login — SQLi test' is infinitely more useful than 'Repeater 14' when you're trying to find something three hours into an engagement.

Tip 5: Use the embedded browser for tricky JS-heavy apps

Some applications use JavaScript-based anti-framing or proxy detection that breaks external browsers. Burp's embedded Chromium browser bypasses most of these protections and is always correctly configured for interception.

Tip 6: Export requests as curl for documentation

Right-click any request in any tool → Copy as curl command. This gives you a reproducible one-liner that you can include directly in penetration test reports as proof of concept.

Tip 7: Test with Burp's Render view before reporting XSS

In Repeater, after sending a request with an XSS payload, click the Render tab in the response pane. Burp renders the response in a live browser-like view so you can see whether your payload actually executes — before writing it up as a finding.

13. Quick Reference Summary

Bookmark this section. It's the one-page version of everything above.

Burp Suite Tab Cheat Sheet

Tab	Primary use	Key shortcut
Proxy	Intercept, view, and log all HTTP/S traffic	<code>Ctrl+Shift+P</code>
Target	Site map, scope definition, engagement tools	<code>Ctrl+Shift+T</code>

Взламывающие
Петли



		Planning (Pro only)	N/A (Community)
		Force, payload	Ctrl+Shift+I
	iteration		
Repeater	Manual request modification and re-sending		Ctrl+Shift+R
Sequencer	Token randomness / entropy analysis		—
Decoder	Encode/decode/hash strings (URL, Base64, HTML, Hex)		Ctrl+Shift+E
Comparer	Diff two requests/responses (word or byte level)		Ctrl+Shift+C
Logger	Full traffic log with advanced filters (Pro only)		N/A (Community)
Organizer	Save and annotate interesting requests		—

Intruder Attack Modes — At a Glance

Mode	Payload sets	Use case	Request count
Sniper	1	Fuzz a single parameter, one at a time	Positions × Payloads

Взламывающие Петли

		e payload in all positions ultaneously	Payloads
Pitchfork	One per position	Credential stuffing (known pairs)	Shortest list length
Cluster Bomb	One per position	Brute force (all combinations)	List A × List B

Must-Have Extensions — Quick List

Extension	Why you need it
Turbo Intruder	Bypasses Community Intruder throttle. Free.
JWT Editor	JWT decode, modify, re-sign, algorithm confusion attacks.
Param Miner	Discovers hidden parameters automatically.
Logger++	Advanced traffic logging and export.
Hackvertor	Multi-layer encoding/decoding chains.
AuthMatrix	Systematic access control testing across roles.
SQLiPy	One-click SQLmap integration inside Burp.



What to learn next

Now that you have Burp Suite down, these are your natural next steps:

- [SQLmap Cheat Sheet](#) — database injection testing, paired perfectly with Burp as a proxy.
- [Gobuster & ffuf Cheat Sheet](#) — directory and endpoint enumeration after mapping your target in Burp.
- [PortSwigger Web Security Academy \(portswigger.net/web-security\)](#) — free labs for every vulnerability type, all solvable with Burp Community.

hackingloops.com · Updated March 2026 · For authorized testing only

This was created for those who want to obtain a lucrative career in cybersecurity. Get this free guide delivered to your email that will show you step-by-step how to get into cybersecurity.

Quick Link

[Home](#)

[About Us](#)

[Membership](#)

[Blog](#)

[Contact Us](#)

Contact Detail

500 Westover Dr #8208, Sanford, NC 27330

Взламывающие Петли



n